

(https://)Tiếp Theo là phần Phân Tích về Detecting Web Attacks

1. Praticice 1 :

SOC165 - Possible SQL Injection Payload Detected

Đây là thông tin chi tiết về Rule

SEVERITY	DATE	RULE NAME	EVENTID	TYPE	ACTION
High	Feb, 25, 2022, 11:34 AM	SOC165 - Possible SQL Injection Payload Detected	115	Web Attack	» ✓
EventID : 115					
Event Time : Feb, 25, 2022, 11:34 AM					
Rule : SOC165 - Possible SQL Injection Payload Detected					
Level : Security Analyst					
Hostname : WebServer1001					
Destination IP Address : 172.16.17.18					
Source IP Address : 167.99.169.17					
HTTP Request Method : GET					
Requested URL : https://172.16.17.18/search?q=%22%20OR%20%3D%20%20-%20-					
User-Agent : Mozilla/5.0 (Windows NT 6.1; WOW64; rv:40.0) Gecko/20100101 Firefox/40.1					
Alert Trigger Reason : Requested URL Contains OR 1 = 1					
Device Action : Allowed					
Show Hint ⚙					

The action was ALLOWED

Sau đó tạo playbook và làm theo yêu cầu có sẵn:

Ownership of the IP addresses and devices.

If the traffic is coming from outside (Internet);

Ownership of IP address (Static or Pool Address? Who owns it? Is it web hosting?)

Reputation of IP Address (Search in VirusTotal, AbuseIPDB, Cisco Talos)

If the traffic is coming from company network;

Hostname of the device

Who owns the device (username)

ok sau các bước trên mình sẽ bắt đầu phân tích. Đầu tiên như thông tin ban đầu đây là cuộc tấn công SQLi

IP : 167.99.169.17 đọc tuy nhiên AV không giải thích nhiều nên mình sử dụng Abuseipdb

167.99.169.17

4

/ 94

Community Score

-16

4/94 security vendors flagged this IP address as malicious

ReanalyzeSimilarMore

167.99.169.17 (167.99.0.0/16)

AS 14061 (DIGITALOCEAN-ASN)

US

Last Analysis Date
1 day ago

DETECTION

DETAILS

RELATIONS

COMMUNITY175

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis ⓘ

Do you want to automate checks?

ArcSight Threat Intelligence	ⓘ Malware	BitDefender	ⓘ Phishing
CyRadar	ⓘ Malicious	G-Data	ⓘ Phishing
alphaMountain.ai	ⓘ Suspicious	AlphaSOC	ⓘ Suspicious

167.99.169.17 was found in our database!

This IP was reported **15,022** times. Confidence of Abuse is **0%**:

?

0%

ISP	DigitalOcean, LLC
Usage Type	Data Center/Web Hosting/Transit
ASN	AS14061
Domain Name	digitalocean.com
Country	 United States of America
City	Santa Clara, California

IP info including ISP, Usage Type, and Location provided by [IPInfo](#). Updated biweekly.

REPORT 167.99.169.17

WHOIS 167.99.169.17

This IP address has been reported a total of **15,022** times from 1,112 distinct sources. 167.99.169.17 was first reported on November 21st 2020, and the most recent report was **1 year** ago.

Old Reports: The most recent abuse report for this IP address is from **1 year** ago. It is possible that this IP is no longer involved in abusive activities.

Reporter	IoA Timestamp in UTC	Comment	Categories
 JA	2023-07-12 14:00:37 (1 year ago)	ssh login attempt	Brute-Force SSH
✓  Esoutien	2023-01-28 20:34:34 (2 years ago)	2023-01-19T12:05:50.310926server.espacesoutien.com sshd [4530]: Invalid user ftpptest from 167.99.169. ... show more	Hacking Brute-Force SSH
✓  zwh	2023-01-28 08:21:00 (2 years ago)	SSH Brute-Force	Brute-Force SSH
 ThreatBook.io	2023-01-22 21:25:50 (2 years ago)	ThreatBook Intelligence: Scanner,Zombie more details on https://threatbook.io/ip/167.99.169.17	SSH
✓  MU-star.net	2023-01-21 09:39:49 (2 years ago)	Invalid user jack from 167.99.169.17 port 41800	Port Scan Brute-Force SSH
✓  itbyhf	2023-01-21 09:05:31 (2 years ago)	Jan 21 04:00:56 ns08 sshd[574347]: Failed password for invalid user ghostuser from 167.99.169.17 port ... show more	Brute-Force SSH
✓ Anonymous	2023-01-21 09:05:13 (2 years ago)	\$f2bV_matches	Brute-Force SSH

Có rất nhiều báo cáo xoay quanh về IP này có nguồn gốc từ HOA Kỳ Requested URL :

[https://172.16.17.18/search/?q=" OR 1 %3D 1 -%20-](https://172.16.17.18/search/?q=)

decode: [https://172.16.17.18/search/?q=" OR 1 = 1 - -](https://172.16.17.18/search/?q=)

Kiểm tra Log Management , chúng ta có thể thấy được attacker đã truy cập vào máy chủ thành công có phản hồi 200

Feb, 25, 2022, 11:34 AM	Firewall	167.99.169.17	48575	172.16.17.18	443	🔍
Feb, 25, 2022, 11:30 AM	Firewall	167.99.169.17	48675	172.16.17.18	443	🔍
Feb, 25, 2022, 11:32 AM	RAW LOG Request URL: https://172.16.17.18/ User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64; rv:40.0) Gecko/20100101 Firefox/40.1 Request Method: GET Device Action: Permitted HTTP Response Size: 3547 HTTP Response Status: 200			172.16.17.18	443	🔍
Feb, 25, 2022, 11:32 AM				172.16.17.18	443	🔍
Feb, 25, 2022, 11:33 AM				172.16.17.18	443	🔍
Feb, 25, 2022, 11:33 AM				172.16.17.18	443	🔍

Tuy nhiên attacker không thể tiếp tục gửi phản hồi đến máy chủ trạng thái 500 đã chứng minh điều đó

DATE	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
Feb, 25, 2022, 11:34 AM	Firewall	167.99.169.17	48575	172.16.17.18	443	🔍
Feb, 25, 2022, 11:30 AM	Firewall	167.99.169.17	48675	172.16.17.18	443	🔍
Feb, 25, 2022, 11:32 AM	RAW LOG Request URL: https://172.16.17.18/search?q=%22%20OR%20%3D%20%20--%20- User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64; rv:40.0) Gecko/20100101 Firefox/40.1 Request Method: GET Device Action: Permitted HTTP Response Size: 948 HTTP Response Status: 500			172.16.17.18	443	🔍
Feb, 25, 2022, 11:32 AM				172.16.17.18	443	🔍
Feb, 25, 2022, 11:33 AM				172.16.17.18	443	🔍
Feb, 25, 2022, 11:33 AM				172.16.17.18	443	🔍

Họ đã gặp lỗi trên máy chủ. bây giờ sẽ kiểm tra các EDR liên quan và hạn chế phát sinh và ngăn ngừa thiệt hại

Chúng ta thấy địa chỉ IP address, 167.99.169.17, là độc hại và nằm ngoài mạng của công ty vì nó không nằm trong EDR. IP nguồn được gửi đến IP đích, 172.16.17.18 là WebServer1001 trên cổng 443.

Endpoint Information	
Host Information	Action
Hostname: WebServer1001	Containment: ☐
IP Address: 172.16.17.18	
OS: Windows Server 2019	
Client/Server: Client	
Domain: letsdefend.local	
Bit Level: 64	
Primary User: webadmin	
Last Login: Feb, 10, 2022, 11:12 PM	

Cuối cùng là kết thúc playbook và đóng vé

×

Is Traffic Malicious?

Decide whether the traffic is malicious or not based on your investigations.

You can find our related training below.

- [Web Attacks 101](#)

Malicious

Non-malicious

Có chọn malicious (Theo như AV)

×

What Is The Attack Type?

Which of the following is the attack vector in the malicious traffic you have detected as a result of your investigations?

Command Injection

IDOR

LFI & RFI

Other

SQL Injection

XML Injection

XSS

← ↺ →

SQLi (decode URL có payload SQLi)

✕

Check If It Is a Planned Test

Penetration tests or attack simulation products can trigger False Positive alarms if the rules are not set correctly. Check whether the malicious traffic is the result of a planned test.

- Check if there is an email showing that there will be planned work by searching for information such as hostname, username, IP address on the mailbox.
- Check if the device generating malicious traffic belongs to attack simulation products. If the Hostname contains the name of Attack Simulation products (such as Verodin, AttackIQ, Picus...), these devices belong to Attack Simulation products within the framework of LetsDefend simulation and it is a planned work.

Is the malicious traffic caused by a planned test?

Not Planned

Planned

← ↺ →

not planned (không tìm thấy các kế hoạch tấn công vào máy chủ)

✕

What Is the Direction of Traffic?

Select the direction of malicious traffic from the available options below.

Format: Source -> Destination

Company Network → Company Network

Company Network → Internet

Internet → Company Network

← ↺ →

Internet -> To company

×

Was the Attack Successful?

Select "Yes" if you found that the attack was successful as a result of your investigations, and "No" if you found that the attack was unsuccessful.

←↺→

No (máy chủ phản hồi 500 sau khi threat actor dùng hàm search)

×

Do You Need Tier 2 Escalation?

Tier 2 escalation should be performed in the following situations.

- In cases where the attack succeeds,
- When the attacker compromises a device in the internal network (in cases where the direction of harmful traffic is from inside → inside),

Tier 2 escalation is not required in the following cases.

- In cases where attacks from the Internet do not succeed

****** Institutions may have their own escalation procedure.
Don't forget to learn about the escalation procedure in your institution.

Perform Tier 2 escalation?

No (cuộc tấn công không thành công nên không cần)

2. Prattice 2

SOC166 - Javascript Code Detected in Requested URL

Như thường lệ mình vẫn mở Rule và xem thông tin chi tiết

Medium

Feb, 26, 2022, 06:56 PM

SOC166 - Javascript Code Detected in Requested URL

116

Web Attack

»

✓

EventID :

T16

Event Time :

Feb, 26, 2022, 06:56 PM

Rule :

SOC166 - Javascript Code Detected in Requested URL

Level :

Security Analyst

Hostname :

WebServer1002

Destination IP Address :

172.16.17.17

Source IP Address :

112.85.42.13

HTTP Request Method :

GET

Requested URL :

https://172.16.17.17/search?q=<\$script>javascript:\$alert()<\$script>

User-Agent :

Mozilla/5.0 (Windows NT 6.1; WOW64; rv:40.0) Gecko/20100101 Firefox/40.1

Alert Trigger Reason :

Javascript code detected in URL

Device Action :

Allowed

Show Hint ⚙

Device Action : Allowed Ip address : 112.85.42.13

Mình sẽ kiểm tra ip có malicious không

112.85.42.13

Sign in

Sig

0
/ 94
Community Score
-13

No security vendor flagged this IP address as malicious
Reanalyze Similar More

112.85.42.13 (112.84.0.0/15)
AS 4837 (CHINA UNICOM China169 Backbone)
CN
Last Analysis Date
16 hours ago

DETECTIONDETAILSRELATIONSCOMMUNITY 7

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis ⓘDo you want to automate checks?

Abusix	✓ Clean	Acronis	✓ Clean
ADMINUSLabs	✓ Clean	AILabs (MONITORAPP)	✓ Clean
AlienVault	✓ Clean	alphaMountain.ai	✓ Clean

Mình sẽ kiểm tra trên abuseipdb để kiểm thêm thông tin abuseipdb

112.85.42.13 was found in our database!

This IP was reported **45,562** times. Confidence of Abuse is **0%**: ?

0%

ISP	China Unicom Jiangsu province network
Usage Type	Fixed Line ISP
ASN	AS4837
Domain Name	chinaunicom.cn
Country	 China
City	Shanghai, Shanghai

IP info including ISP, Usage Type, and Location provided by [IPInfo](#). Updated biweekly.

REPORT 112.85.42.13

WHOIS 112.85.42.13

Ip này

xuất phát từ China với domain [chinaunicom.cn](#) Và khi kiểm tra báo cáo thì nó độc hại

IP Abuse Reports for 112.85.42.13:

This IP address has been reported a total of **45,562** times from 478 distinct sources. 112.85.42.13 was first reported on November 21st 2020, and the most recent report was **1 year ago**.

Old Reports: The most recent abuse report for this IP address is from **1 year ago**. It is possible that this IP is no longer involved in abusive activities.

Reporter	IoA Timestamp in UTC	Comment	Categories
✓ Anonymous	2023-04-27 19:45:54 (1 year ago)	fail2ban detected brute force on sshd	Brute-Force SSH
✓ Anonymous	2023-03-06 02:07:35 (1 year ago)	fail2ban detected brute force on sshd	Brute-Force SSH
✓ Anonymous	2022-12-06 17:09:07 (2 years ago)	fail2ban detected brute force on sshd	Brute-Force SSH
✓ Anonymous	2022-11-30 19:18:48 (2 years ago)	fail2ban detected brute force on ssh iptables	Brute-Force SSH

Cùng kiểm tra thêm về URL:

[https://172.16.17.17/search/?q=<script> javascript :alert\(1\)</script>](https://172.16.17.17/search/?q=<script> javascript :alert(1)</script>)

attacker đã chèn payload kiểm tra hệ thống có dễ bị XSS hay không. Nếu thành công khi truy cập URL hệ trình duyệt sẽ hiển thị thông báo "1".

Tiếp theo mình sẽ đi kiểm tra Raw log :

Show Filter

BasicPro

112.85.42.13

DATE	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
Feb, 26, 2022, 06:34 PM	Firewall	112.85.42.13	49183	172.16.17.17	443	🔍
Feb, 26, 2022, 06:35 PM	Firewall	112.85.42.13	49182	172.16.17.17	443	🔍
Feb, 26, 2022, 06:45 PM	Firewall	112.85.42.13	48189	172.16.17.17	443	🔍
Feb, 26, 2022, 06:46 PM	Firewall	112.85.42.13	47283	172.16.17.17	443	🔍
Feb, 26, 2022, 06:46 PM	Firewall	112.85.42.13	49183	172.16.17.17	443	🔍
Feb, 26, 2022, 06:53 PM	Firewall	112.85.42.13	49263	172.16.17.17	443	🔍
Feb, 26, 2022, 06:50 PM	Firewall	112.85.42.13	49243	172.16.17.17	443	🔍
Feb, 26, 2022, 06:56 PM	Firewall	112.85.42.13	49283	172.16.17.17	443	🔍

DATE	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
Feb, 26, 2022, 06:34 PM	Firewall	112.85.42.13	49183	172.16.17.17	443	🔍
Feb, 26, 2022, 06:35 PM	Firewall	112.85.42.13	49182	172.16.17.17	443	🔍
Feb, 26, 2022, 06:45 PM	RAW LOG Request URL: https://172.16.17.17/search/?q=test User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64; rv:40.0) Gecko/20100101 Firefox/40.1 Request Method: GET Device Action: Permitted HTTP Response Size: 885 HTTP Response Status: 200			172.16.17.17	443	🔍
Feb, 26, 2022, 06:46 PM				172.16.17.17	443	🔍
Feb, 26, 2022, 06:46 PM				172.16.17.17	443	🔍
Feb, 26, 2022, 06:53 PM				172.16.17.17	443	🔍
Feb, 26, 2022, 06:50 PM				172.16.17.17	443	🔍
Feb, 26, 2022, 06:56 PM				172.16.17.17	443	🔍

Để thấy được attacker đã được truy cập vào máy chủ

RAW LOG

Request URL: https://172.16.17.17/search/?q=<\$script>javascript:\$alert(1)
User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64; rv:40.0) Gecko/20100101 Firefox/40.1
Request Method: GET
Device Action: Permitted
HTTP Response Size: 0
HTTP Response Status: 302

Tuy nhiên khi

chèn các payload XSS bị trả về status 302 chứng tỏ cuộc tấn công đã bị chuyển hướng nên không thành công.

Vào EDR xem các thiết bị nào liên quan đến cuộc tấn công này:

Endpoint Information

Host Information

Hostname:	WebServer1002	Domain:	letsdefend.local
IP Address:	172.16.17.17	Bit Level:	64
OS:	Windows Server 2019	Primary User:	webadmin15
Client/Server:	Client	Last Login:	Feb, 02, 2022, 03:40 PM

Ở đây chúng ta có nắm được thông tin như sau :

địa chỉ 112.85.42.13, là IP độc hại và nằm ngoài mạng của công ty (không có trong danh sách EDR công ty) IP nguồn được gửi đến IP đích, 172.16.17.17 là WebServer1002 thông qua cổng 443.

Trả lời các câu hỏi trong report nào !!!



Is Traffic Malicious?

Decide whether the traffic is malicious or not based on your investigations.

You can find our related training below.

- [Web Attacks 101](#)

Malicious

Non-malicious

malicious

What Is The Attack Type?

Which of the following is the attack vector in the malicious traffic you have detected as a result of your investigations?

XSS

Command Injection

IDOR

LFI & RFI

Other

SQL Injection

XML Injection

XSS

Check If It Is a Planned Test

Penetration tests or attack simulation products can trigger False Positive alarms if the rules are not set correctly. Check whether the malicious traffic is the result of a planned test.

- Check if there is an email showing that there will be planned work by searching for information such as hostname, username, IP address on the mailbox.
- Check if the device generating malicious traffic belongs to attack simulation products. If the Hostname contains the name of Attack Simulation products (such as Verodin, AttackIQ, Picus...), these devices belong to Attack Simulation products within the framework of LetsDefend simulation and it is a planned work.

Not

Is the malicious traffic caused by a planned test?

Not Planned

Planned

planned đây không phải là cuộc tấn công lên kế hoạch sẵn vì kiểm tra IP/nguồn.đích.tên máy chủ /URL không có gì

What Is the Direction of Traffic?

Select the direction of malicious traffic from the available options below.

Format: Source -> Destination

Company Network → Company Network

Company Network → Internet

Internet → Company Network

internet ->

company Vì ip 112.85.42.13 bắt nguồn từ Trung quốc và chèn payload độc hại vào web sever 1002 172.16.17.12 ip đích

Was the Attack Successful?

Select "Yes" if you found that the attack was successful as a result of your investigations, and "No" if you found that the attack was unsuccessful.

No, cuộc tấn

No

Yes

công bị chuyển hướng (302 status)

×

Do You Need Tier 2 Escalation?

Tier 2 escalation should be performed in the following situations.

- In cases where the attack succeeds,
- When the attacker compromises a device in the internal network (in cases where the direction of harmful traffic is from inside → inside),

Tier 2 escalation is not required in the following cases.

- In cases where attacks from the Internet do not succeed

**** Institutions may have their own escalation procedure. Don't forget to learn about the escalation procedure in your institution.**

Perform Tier 2 escalation?

No

Yes

No, cuộc tấn công không thành công

×

Close Alert

Event ID :

116

☒ True Positive ☐ False Positive

Note:

Message

Close Alert

Đóng ticker !!

3. ****PRATICE 3 ****

SOC167 - LS Command Detected in Requested URL

Thông tin chi tiết về Rule

High		Feb, 27, 2022, 12:36 AM	SOC167 - LS Command Detected in Requested URL	117	Web Attack
EventID :	117				
Event Time :	Feb, 27, 2022, 12:36 AM				
Rule :	SOC167 - LS Command Detected in Requested URL				
Level :	Security Analyst				
Hostname :	EliotPRD				
Destination IP Address :	188.114.96.15				
Source IP Address :	172.16.17.46				
HTTP Request Method :	GET				
Requested URL :	https://letsdefend.io/blog/7s=skills				
User-Agent :	Mozilla/5.0 (X11; Ubuntu; Linux i686; rv:24.0) Gecko/20100101 Firefox/24.0				
Alert Trigger Reason :	URL Contains LS				
Device Action :	Allowed				
Show Hint					

Device Action : Allowed Nhận thấy Ip nguồn : 188.114.96.15

Kiểm tra ip trên Av

188.114.96.15

Did you intend to search across the file corpus instead? [Click here](#)

0

/ 94

Community Score

2

9 detected files communicating with this IP address

Reanalyze

Similar

More

188.114.96.15 (188.114.96.0/22)

AS 13335 (CLOUDFLARENET)

suspicious-udp

Last Analysis Date

1 day ago

DETECTION

DETAILS

RELATIONS

COMMUNITY 2

Join our Community

 and enjoy additional community insights and crowdsourced detections, plus an API key to [automate checks](#).

Security vendors' analysis

Do you want to automate checks?

Abusix	✓ Clean	Acronis	✓ Clean
ADMINUSLabs	✓ Clean	AILabs (MONITORAPP)	✓ Clean
AlienVault	✓ Clean	alphaMountain.ai	✓ Clean
Antiy-AVL	✓ Clean	benkow.cc	✓ Clean

Tiếp tục kiểm tra bên AbuseIPDB

188.114.96.15 was found in our database!

This IP was reported 4 times. Confidence of Abuse is 0%: ?

0%

ISP

CloudFlare, Inc.

Usage Type

Content Delivery Network

ASN

AS13335

Domain Name

cloudflare.com

Country

 Germany

City

Munich, Bavaria

IP info including ISP, Usage Type, and Location provided by [IPInfo](#). Updated biweekly.

Important Note:

188.114.96.15 is an IP address from within our whitelist belonging to the subnet [188.114.96.0/20](#), which we identify as:

Kiểm tra các báo cáo

This IP address has been reported a total of 4 times from 4 distinct sources. 188.114.96.15 was first reported on June 22nd 2022, and the most recent report was 1 year ago.

Old Reports: The most recent abuse report for this IP address is from 1 year ago. It is possible that this IP is no longer involved in abusive activities.

Reporter	IoA Timestamp in UTC	Comment	Categories
 ps-center	2023-05-09 15:18:50 (1 year ago)	C1-W: TCP-Scanner. Port: 22	Port Scan
 StatsMe	2022-06-22 17:18:06 (2 years ago)	2022-06-22T13:55:49.833490+0300 ET DOS Possible NTP DD oS Inbound Frequent Un-Authed MON_LIST R ... show more	DDoS Attack
 IP Analyzer	2022-06-22 13:15:41 (2 years ago)	Unauthorized connection attempt from IP address 188.114.96.15 on Port 80(HTTP)	Brute-Force
 Anonymous	2022-06-22 11:25:19 (2 years ago)	2:Unauthorized connection attempt detected	Hacking Brute-Force Bad Web Bot Web App Attack

Tiếp theo kiểm tra trên URL :

<https://letsdefend.io/blog/?s=skills>

ở đây ta có thể thấy cảnh báo được xuất hiện lý do chứa ls và vô tình skills có chứa "ls". Oke để rõ ràng hơn ta cần phân tích Raw log

DATE ↑	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
Feb, 27, 2022, 12:36 AM	Proxy	172.16.17.46	46843	188.114.96.15	443	
Feb, 27, 2022, 12:37 AM	Proxy	172.16.17.46	47473	188.114.96.15	443	
Feb, 27, 2022, 12:35 AM	Proxy	172.16.17.46	48463	188.114.96.15	443	
Feb, 27, 2022, 12:23 AM	Proxy	172.16.17.46	49843	188.114.96.15	443	
Feb, 27, 2022, 12:13 AM	Proxy	172.16.17.46	49273	188.114.96.15	443	
Feb, 27, 2022, 12:05 AM	Proxy	172.16.17.46	49122	188.114.96.15	443	
Feb, 27, 2022, 12:01 AM	Proxy	172.16.17.46	48123	188.114.96.15	443	

Ở đây ta có thể thấy ip nguồn là 172.16.17.46 tức là ip từ công ty được gửi ra ngoài đến cổng 443 của ip đích 188.114.96.15 domain ở bên Đức (cloudflare)

RAW LOG

Request URL:

https://letsdefend.io/blog/?s=skills

User-Agent:

Mozilla/5.0 (X11; Ubuntu; Linux i686; rv:24.0) Gecko/20100101 Firefox/24.0

Request Method:

GET

Device Action:

Permitted

HTTP Response Size::

2577

HTTP Response Status:

200

Ở phần raw log chúng ta có thể thấy phương thức http GET yêu cầu tài nguyên từ máy chủ .

Host Information

Hostname:

EliotPRD

Domain:

letsdefend.local

IP Address:

172.16.17.46

Bit Level:

64

OS:

Ubuntu 16.04.4

Primary User:

eliot

Client/Server:

Client

Last Login:

Feb, 27, 2022, 12:00 AM

và được kết nối với

EDR username : EloitPRD Kiểm tra browser history và network

EVENT TIME	DOMAIN NAME/URL
27.02.2022 00:01	https://letsdefend.io/blog/
27.02.2022 00:05	https://letsdefend.io/blog/how-to-become-a-soc-analyst/
27.02.2022 00:13	https://letsdefend.io/blog/how-to-analyze-rtf-template-injection-attacks/
27.02.2022 00:23	https://letsdefend.io/blog/red-team-vs-blue-team-learn-the-difference/
27.02.2022 00:35	https://letsdefend.io/blog/how-to-prepare-soc-analyst-resume/
27.02.2022 00:36	https://letsdefend.io/blog/?s=skills
27.02.2022 00:37	https://letsdefend.io/blog/soc-analyst-career-without-a-degree/

Trong browser history chúng ta có thể thấy thời gian thực hiện các hành động ngắn nhưng các URL hoàn toàn vô hại. Và bên cạnh đó khi kiểm tra trên các AV hoặc AbuseIPDB không thấy malicious. và domain name là cloudflare.com

EVENT TIME	DESTINATION DOMAIN/IP ADDRESS
27.02.2022 00:01	188.114.96.15
27.02.2022 00:05	188.114.96.15
27.02.2022 00:13	188.114.96.15
27.02.2022 00:23	188.114.96.15
27.02.2022 00:35	188.114.96.15
27.02.2022 00:36	188.114.96.15
27.02.2022 00:37	188.114.96.15

Hoàn toàn trùng khớp

Sau tất cả các phân tích thì chắc chắn đây là lưu lượng an toàn.

Is Traffic Malicious?

Decide whether the traffic is malicious or not based on your investigations.

You can find our related training below.

- [Web Attacks 101](#)

Malicious

Non-malicious

Non-

Is There a Different Request/Traffic?

Even if the HTTP Request that triggers the rule is harmless, there may be different malicious traffic coming from the same source device. For this reason, it should be checked whether there is different traffic from the source address.

Check if there is different traffic from the same source address. Choose 'Yes' if there is any different traffic. Otherwise, choose 'No'

No

Yes

Malicious

Yes

Close Alert

Event ID :

117

☐ True Positive ☒ False Positive

Note:

Message

Close Alert

★ SOC146 - Phishing Mail Detected - Excel 4.0 Macros

Nó là cảnh báo

False Positive.

4. **Practive 4 **

SOC168 - Whoami Command Detected in Request Body

Tiếp tục đến với 1 Rule khác

High Feb, 28, 2022, 04:12 AM SOC168 - Whoami Command Detected in Request Body 118 Web Attack

EventID :	118
Event Time :	Feb, 28, 2022, 04:12 AM
Rule :	SOC168 - Whoami Command Detected in Request Body
Level :	Security Analyst
Hostname :	WebServer1004
Destination IP Address :	172.16.17.16
Source IP Address :	61.177.172.87
HTTP Request Method :	POST
Requested URL :	https://172.16.17.16/video/
User-Agent :	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; SV1)
Alert Trigger Reason :	Request Body Contains whoami string
Device Action :	Allowed
Show Hint ⚙	

Device Action : Allowed Ip nguồn : 61.177.172.07 ip đích : 172.16.17.16

Check ip trên AV

61.177.172.87

Did you intend to search across the file corpus instead? [Click here](#)

5 / 94
Community Score

5/94 security vendors flagged this IP address as malicious

61.177.172.87 (61.177.128.0/17)
AS 4134 (Chinanet)

CN Last Analysis Date 8 hours ago

DETECTION DETAILS RELATIONS COMMUNITY 61

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to [automate checks](#).

Security vendors' analysis ⓘ Do you want to automate checks?

alphaMountain.ai	Malicious	CyRadar	Malicious
Forcepoint ThreatSeeker	Malicious	Fortinet	Malware
SOCRadar	Malware	AlphaSOC	Suspicious

cảnh báo được đưa ra là Ip độc

Đối với AbuseIPDB ta thấy được nguồn ip đến từ China và domain name ở chinatelecom.cn

61.177.172.87 was found in our database!

This IP was reported **87,442** times. Confidence of Abuse is **0%**: ?

0%

ISP	CHINANET jiangsu province network
Usage Type	Fixed Line ISP
ASN	AS4134
Domain Name	chinatelecom.cn
Country	 China
City	Shanghai, Shanghai

IP info including ISP, Usage Type, and Location provided by [IPInfo](#). Updated biweekly.

[REPORT 61.177.172.87](#)[WHOIS 61.177.172.87](#)

IP Abuse Reports for 61.177.172.87:

This IP address has been reported a total of **87,442** times from 536 distinct sources. 61.177.172.87 was first reported on January 7th 2022, and the most recent report was **1 year ago**.

Kiểm tra Raw log ở Log Management có 5 alerts ở đây:

DATE ↑	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
Feb, 28, 2022, 04:12 AM	Firewall	61.177.172.87	49821	172.16.17.16	443	
Feb, 28, 2022, 04:11 AM	Firewall	61.177.172.87	49822	172.16.17.16	443	
Feb, 28, 2022, 04:13 AM	Firewall	61.177.172.87	49222	172.16.17.16	443	
Feb, 28, 2022, 04:14 AM	Firewall	61.177.172.87	48822	172.16.17.16	443	
Feb, 28, 2022, 04:15 AM	Firewall	61.177.172.87	46822	172.16.17.16	443	

Chúng ta có thể thấy được thông tin Ip nguồn 61.177.172.87 từ China gửi đến ip đích 172.16.17.16 một EDR trên Letdefend mang tên : Webserver1004 Thông qua cổng 443

```
Request URL: https://172.16.17.16/video/
User-Agent: Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; SV1)
Request Method: POST
Device Action: Permitted
HTTP Response Size:: 1321
HTTP Response Status: 200
POST Parameters: ?c=cat /etc/passwd
```

Request URL: `https://172.16.17.16/video/`
User-Agent: `Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; SV1)`
Request Method: `POST`
Device Action: `Permitted`
HTTP Response Size: `1501`
HTTP Response Status: `200`
POST Parameters: `?c=cat /etc/shadow`

Dựa vào phương thức http POST attacker đã chèn các commandline và gửi chúng đến máy chủ để xử lý trong phần request body thông qua tham số `?c=`. `?c=cat /etc/shadow` hoặc `?c=cat /etc/passwd` Máy chủ đã chấp nhận thực thi các lệnh này (xác định ở status 200) Tác hại làm lộ thông tin mật khẩu được mã hóa của người dùng trên hệ thống Linux (`/etc/shadow`) hoặc thông tin tài khoản người dùng(`/etc/passwd`)

Kiểm tra xem các EDR nào liên quan để cách ly và ngăn chặn kịp thời.

Endpoint Information

Host Information

Hostname: WebServer1004

Domain: letsdefend.local

IP Address: 172.16.17.16

Bit Level: 64

OS: Ubuntu 20.04.02

Primary User: webadmin3

Client/Server: Server

Last Login: Feb, 08, 2022, 11:11 AM

Action

Containment: ☒ Host Contained

Việc attacker yêu cầu máy chủ xử lý các lệnh hoàn toàn trùng khớp tại Terminal History

EVENT TIME	COMMAND LINE
08.02.2022 16:21	<code>docker-compose -f docker-compose-deploy.yml build</code>
08.02.2022 16:36	<code>docker-compose -f docker-compose-deploy.yml up</code>
28.02.2022 04:11	<code>ls</code>
28.02.2022 04:12	<code>whoami</code>
28.02.2022 04:13	<code>uname</code>
28.02.2022 04:14	<code>cat /etc/passwd</code>
28.02.2022 04:17	<code>cat /etc/shadow</code>

Is Traffic Malicious?

Decide whether the traffic is malicious or not based on your investigations.

You can find our related training below.

- [Web Attacks 101](#)

Malicious

Non-malicious

Is There a Different Request/Traffic?

Even if the HTTP Request that triggers the rule is harmless, there may be different malicious traffic coming from the same source device. For this reason, it should be checked whether there is different traffic from the source address.

Malicious

Yes

Check if there is different traffic from the same source address. Choose 'Yes' if there is any different traffic. Otherwise, choose 'No'

No

Yes

Is Traffic Malicious?

Decide whether the traffic is malicious or not based on your investigations.

You can find our related training below.

- [Web Attacks 101](#)

Malicious

Non-malicious

Malicious

What Is The Attack Type?

Which of the following is the attack vector in the malicious traffic you have detected as a result of your investigations?

Command Injection

IDOR

LFI & RFI

Other

SQL Injection

XML Injection

XSS

Command

Check If It Is a Planned Test

Penetration tests or attack simulation products can trigger False Positive alarms if the rules are not set correctly. Check whether the malicious traffic is the result of a planned test.

- Check if there is an email showing that there will be planned work by searching for information such as hostname, username, IP address on the mailbox.
- Check if the device generating malicious traffic belongs to attack simulation products. If the Hostname contains the name of Attack Simulation products (such as Verodin, AttackIQ, Picus...), these devices belong to Attack Simulation products within the framework of LetsDefend simulation and it is a planned work.

Is the malicious traffic caused by a planned test?

Not Planned

Planned

injection

What Is the Direction of Traffic?

Select the direction of malicious traffic from the available options below.

Format: Source -> Destination

Company Network → Company Network

Company Network → Internet

Internet → Company Network

Not Planned

Internet -> company

Was the Attack Successful?

Select "Yes" if you found that the attack was successful as a result of your investigations, and "No" if you found that the attack was unsuccessful.

Yes

No

Yes

Do You Need Tier 2 Escalation?

Tier 2 escalation should be performed in the following situations.

- In cases where the attack succeeds,
- When the attacker compromises a device in the internal network (in cases where the direction of harmful traffic is from inside → inside),

Tier 2 escalation is not required in the following cases.

- In cases where attacks from the Internet do not succeed

Yes

****** Institutions may have their own escalation procedure.
Don't forget to learn about the escalation procedure in your institution.

Perform Tier 2 escalation?

No

Yes

Close Alert

Event ID :

118

☒ True Positive ☐ False Positive

Note:

Message

Close Alert

true positive